RELATÓRIO TÉCNICO: DETECÇÃO DO SPYWARE PEGASUS VIA NAIVE BAYES

Universidade Cidade de São Paulo (UNICID)

Ciência de Dados e Aprendizado de Máquina

Gian Lucca Panzone

09/11/2026

RESUMO

Este relatório descreve o desenvolvimento de um modelo probabilístico baseado no algoritmo Categorical Naive Bayes para a detecção de anomalias de rede e exfiltração de dados associadas ao spyware Pegasus. Utilizando um conjunto de dados sintético de 1.000 registros de telemetria, o modelo alcançou uma sensibilidade (Recall) de 93,78%, demonstrando viabilidade como ferramenta de triagem inicial em Centros de Operações de Segurança (SOC). O trabalho discute ainda as implicações legais e éticas do uso de malwares de interceptação no âmbito investigativo e policial.

1. INTRODUÇÃO E CONTEXTUALIZAÇÃO

1.1. O Desafio do Spyware Pegasus

O monitoramento e a segurança de dispositivos móveis enfrentam desafios sem precedentes com o surgimento de malwares avançados como o Pegasus, desenvolvido pela NSO Group. Diferente de ataques de phishing tradicionais, o Pegasus atua por meio de vulnerabilidades zero-click. Isso significa que a intrusão ocorre sem qualquer interação da vítima, explorando falhas silenciosas no sistema operacional para tomar controle de microfones, câmeras e dados armazenados, transformando o dispositivo em um terminal de vigilância contínua.

Uma vez que o artefato malicioso se oculta profundamente no sistema, a sua detecção em nível de dispositivo (endpoint) é altamente complexa. No entanto, para que o ataque seja efetivo, os dados roubados precisam ser exfiltrados para um servidor de Comando e Controle (C2). É neste ponto que a Aprendizagem de Máquina atua: analisando a telemetria da rede em busca de assinaturas comportamentais e estatísticas desse tráfego furtivo.

1.2. Implicações Legais e o Uso Policial

Embora o Pegasus seja comercializado sob a justificativa de auxiliar governos soberanos no combate ao terrorismo e ao crime organizado, seu uso levanta complexos debates jurídicos. No âmbito legal, a interceptação telemática por meio de malwares difere drasticamente do grampo telefônico tradicional.

Enquanto um grampo intercepta dados em trânsito na operadora (amparado, no Brasil, pela Lei 9.296/96), o Pegasus realiza uma intrusão no endpoint, acessando dados em repouso e comunicações antes da criptografia de ponta a ponta. O uso de tais ferramentas por forças policiais sem mandados judiciais estritamente tipificados para "busca e apreensão digital remota" pode caracterizar violação de garantias constitucionais, resultando na ilicitude e anulação de provas em processos criminais. O alto risco de desvio de finalidade (como a espionagem política) reforça a necessidade de sistemas de defesa e detecção robustos.

2. FUNDAMENTAÇÃO TEÓRICA

O modelo preditivo adotado baseia-se no Teorema de Bayes, que calcula a probabilidade a posteriori de um fluxo de rede ser malicioso dadas as evidências (features) observadas:

$$P(Y \mid X_1, \ldots, X_n) = \frac{P(Y)\prod_{i=1}^{n} P(X_i|Y)}{P(X_1,\ldots,X_n)}$$

A escolha pela variante Categorical Naive Bayes (CategoricalNB) justifica-se pela natureza discreta dos dados de log de rede (protocolos, portas, tipos de processos).

2.1. A Hipótese de Independência Condicional

O algoritmo assume, de forma "ingênua" (naive), que todos os atributos são independentes entre si, dada a classe. Na cibersegurança do mundo real, essa premissa é violada, pois um processo suspeito frequentemente possui forte correlação estatística com o protocolo de rede utilizado. Apesar dessa violação distorcer as probabilidades absolutas, o modelo mantém alta eficácia na ordenação das classes, sendo computacionalmente leve para processar milhões de logs em tempo real.

3. METODOLOGIA E TRATAMENTO DE DADOS

O projeto utilizou um dataset de telemetria contendo atributos de sistema e rede. O fluxo de pré-processamento seguiu as seguintes etapas

- **Definição da Variável-Alvo:** Rótulo binário (1 para Malicioso, 0 para Legítimo).
- **Imputação de Dados:** Tratamento de valores nulos na coluna de detecção de anomalias, categorizando-os como ausência de alertas ('None').
- **Discretização por Quantis:** A variável contínua referente ao volume de dados transferidos foi transformada em quatro faixas categóricas de frequências equiprováveis (quartis).
- **Codificação Ordinal:** Conversão de rótulos textuais (ex: 'HTTPS', 'malware.exe') em representações numéricas discretas exigidas pelo algoritmo, através do OrdinalEncoder.
- **Suavização de Laplace:** Aplicação do parâmetro $\alpha = 1.0$ durante o treinamento para evitar o problema de probabilidade zero em categorizações não vistas no conjunto de treino.

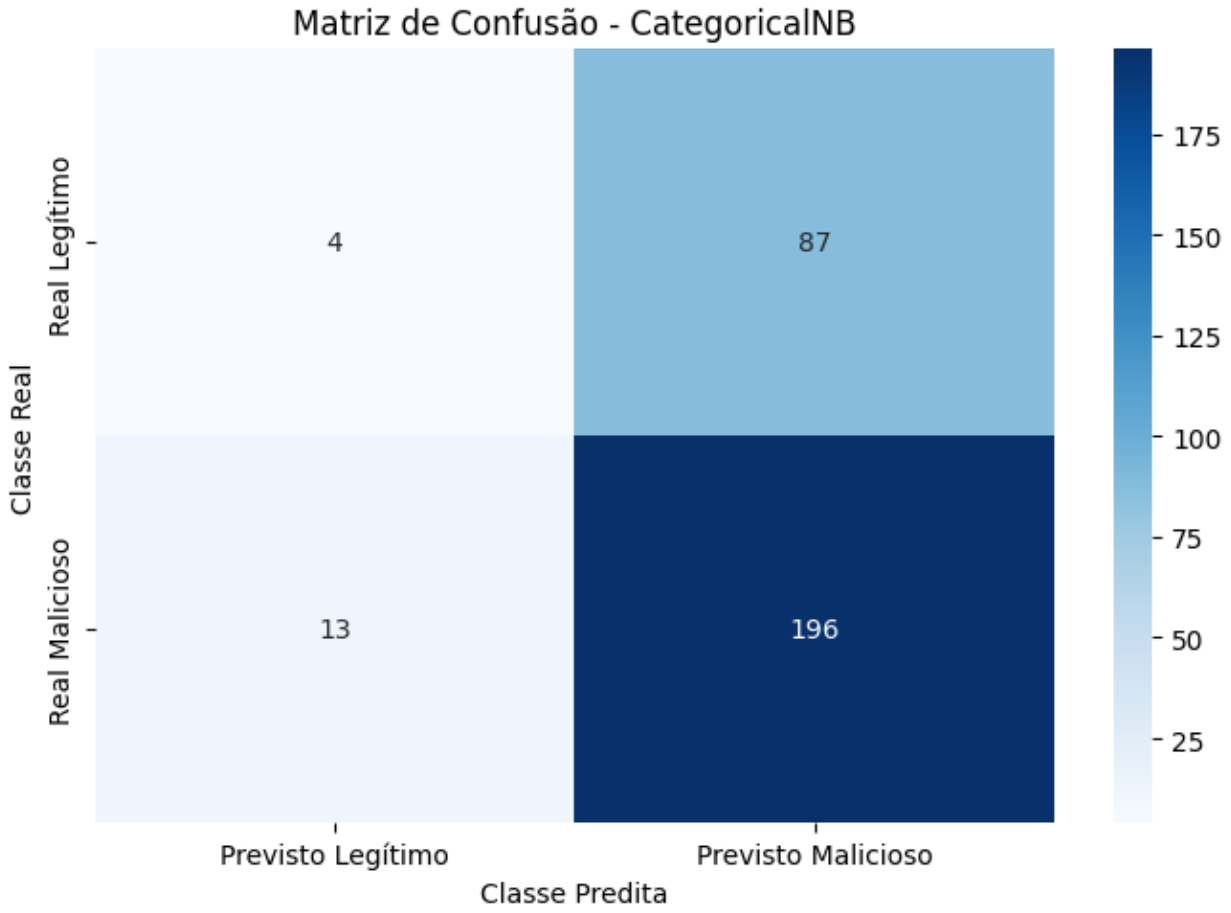
4. RESULTADOS E ANÁLISE CRÍTICA

O modelo foi avaliado em um conjunto de teste contendo 300 amostras, priorizando a capacidade de captura de ameaças ativas.

- Acurácia: 66,67%
- Precisão: 69,26%
- Recall (Sensibilidade): 93,78%
- F1-Score: 79,67%

4.1. Interpretação Operacional (Matriz de Confusão)

O resultado mais expressivo para o contexto de um Centro de Operações de Segurança (SOC) é a taxa de Recall (93,78%). O classificador foi capaz de identificar corretamente 196 de 209 requisições maliciosas.



A alta taxa de detecção tem como trade-off uma geração de 87 Falsos Positivos (tráfego legítimo classificado como ameaça). No domínio defensivo, este comportamento é desejável: é preferível onerar a equipe de triagem humana com alertas benignos atípicos a permitir que malwares silenciosos (Falsos Negativos, que somaram apenas 13 casos) operem sem detecção.

5. CONCLUSÃO

O classificador probabilístico Categorical Naive Bayes demonstrou ser uma ferramenta altamente viável para a triagem inicial de logs de telemetria. Sua implementação confirmou que, mesmo diante de premissas simplificadas de independência condicional, o rastreamento do "comportamento de rede" (exfiltração) é uma estratégia eficaz para combater ameaças invisíveis no endpoint, como o Pegasus.